

MODULE 45 · EXAM STRATEGY - ALL DOMAINS

Practice Exam: Domain 1

Fifteen questions on organisational complexity. Pause, decide, then watch.

DOMAIN 1 of 4 EXAM WEIGHT 26% SET 1 of 5

How to use this set

- ◆ **Give yourself 2.4 minutes per question.** That is the real exam's budget, and fifteen questions is 36 minutes.
- ◆ **Write your answer down before unpausing.** Reading the walkthrough first teaches you nothing about what you knew.
- ◆ **Note which ones you guessed,** even when you guessed correctly. Those are the gaps.
- ◆ The final slide maps every question to a module, so a miss tells you exactly what to rewatch.

ON THE EXAM

A question you guessed right is a question you got wrong. Track guesses separately or the score flatters you.

A company must guarantee that no principal, in any member account, can share an S3 bucket with an AWS account outside the organisation. Several teams legitimately share buckets with partner accounts that have been added to the organisation. The management account must also be covered.

Control Tower is deployed.

Which approach meets the requirement?

- ☐ A An RCP denying s3 actions where aws:PrincipalOrgID does not match the organisation
- ☐ B An SCP denying s3:PutBucketPolicy across all OUs
- ☐ C A Config rule detecting externally shared buckets, with automatic remediation
- ☐ D S3 Block Public Access enabled account-wide in every account

◆ PAUSE AND DECIDE

Which approach meets the requirement?

- A

 RCP on PrincipalOrgID
RCPs apply to the resource, so access from outside the org is refused regardless of caller. RCPs also apply to the management account, unlike SCPs.
- B

 SCP denying PutBucketPolicy
Blocks legitimate internal sharing too, and SCPs do not apply to the management account.
- C

 Config plus remediation
"Guarantee" is preventive. Detection leaves a window, however brief.
- D

 Block Public Access
Stops public access. Sharing with a named external AWS account is not public access.

THE SIGNAL

Two clues: "guarantee" forces preventive, and "the management account must also be covered" rules out SCPs. Module 02.

An organisation has 400 accounts. Developers currently receive IAM users in each account they need. Onboarding takes four days, and an audit found 61 users belonging to people who left. The company uses Okta as its corporate identity provider. Access must be revocable centrally within minutes.

What should the solutions architect recommend?

- ☐ A A central identity account with cross-account roles assumed from IAM users
- ☐ B A SAML identity provider configured in each of the 400 accounts
- ☐ C IAM Identity Center with Okta as the identity source, and permission sets assigned to groups
- ☐ D AWS Managed Microsoft AD with a trust to Okta

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 Central account with IAM users
Better than 400 user sets, and still long-lived credentials that must be deprovisioned manually.
- B

 SAML provider per account
400 configurations to maintain and 400 places to update when a role changes. Identity Center exists to remove this.
- C

 Identity Center with Okta
One identity source, permission sets deployed across all 400 accounts, and disabling in Okta revokes everywhere. No long-lived credentials.
- D

 Managed AD with a trust
Adds a directory the company does not need. Okta federates to Identity Center directly.

THE SIGNAL

Leavers retaining access is the signal for federation, not for better process. Module 04.

Three VPCs are attached to a Transit Gateway. VPC A and VPC B must reach each other. VPC C is a shared services VPC that both must reach, but A and B must not reach each other through it. An engineer has associated all three with the default route table and enabled propagation from all three.

Traffic currently flows between all three VPCs.

What change achieves the requirement?

- ☐ A Use separate route tables: associate A and B with one that has C propagated, and associate C with one that has A and B propagated
- ☐ B Add security group rules denying traffic between A and B
- ☐ C Remove the propagation from VPC C's attachment
- ☐ D Replace the Transit Gateway with VPC peering between A-C and B-C

◆ PAUSE AND DECIDE

What change achieves the requirement?

A Separate route tables

The near-miss. Read the stem again: A and B must reach each other. This isolates them, which the requirement does not ask for.

C Remove C's propagation

Stops A and B learning routes to C, which breaks the shared services access they need.

B Security group rules

Security groups have no deny rules. This is not something they can express.

D VPC peering A-C and B-C

Peering is non-transitive, so A and B cannot reach each other through C, while both reach C directly. That is exactly the stated requirement.

THE SIGNAL

Read the requirement twice. A and B **MUST** reach each other, and must not do so **THROUGH C**. Non-transitivity gives you both. Module 06.

A company connects to AWS with a single 10 Gbps Direct Connect connection from one location, terminating on one device. It requires resilience against device failure, location failure and connection failure, and has budget for additional connections. The workload cannot tolerate falling back to the internet.

What is the MINIMUM configuration that meets all three requirements?

- ☐ A Two connections at the same location, on separate devices
- ☐ B Two connections at two different locations, each on a separate device
- ☐ C One connection plus a Site-to-Site VPN as backup
- ☐ D Four connections across two locations, two at each

◆ PAUSE AND DECIDE

What is the MINIMUM configuration that meets all three requirements?

- A

 Two at one location
Covers device and connection failure. A location failure takes both out.
- B

 Two locations, separate devices
Covers all three failure modes with the fewest connections, which is what MINIMUM asks for.
- C

 One connection plus VPN
The VPN traverses the internet, which the scenario rules out explicitly.
- D

 Four connections
Meets the requirements and exceeds them. MINIMUM makes this wrong despite being more resilient.

THE SIGNAL

MINIMUM is doing work here. Option D is not incorrect architecture; it is the wrong answer to the question asked. Module 07.

On-premises applications must resolve records in a Route 53 private hosted zone in AWS. AWS-hosted applications must resolve internal names held by on-premises DNS servers. A Direct Connect link exists between the environments. Both directions currently fail.

What is required?

- ☐ A A Route 53 Resolver inbound endpoint only
- ☐ B A Route 53 Resolver outbound endpoint only, with forwarding rules
- ☐ C Both inbound and outbound Resolver endpoints, with forwarding rules for the on-premises domains
- ☐ D Conditional forwarding configured on the on-premises DNS servers alone

◆ PAUSE AND DECIDE

What is required?

- A

Inbound only

Solves on-premises querying AWS. AWS querying on-premises still fails.
- B

Outbound only

Solves AWS querying on-premises. The other direction still fails.
- C

Both, with forwarding rules

Both directions are stated as failing, so both endpoints are needed. Inbound receives queries; outbound forwards them.
- D

Conditional forwarding alone

On-premises servers need an inbound endpoint IP to forward to. Configuring forwarding with no target does nothing.

THE SIGNAL

"Both directions currently fail" is the whole question. Answering with one endpoint is the common half-correct response. Module 08.

A security team must retain CloudTrail logs from 200 accounts for seven years, in a form that no administrator in any account, including the Log Archive account, can alter or delete. Auditors must be able to query the logs.

The company uses Control Tower.

Which combination meets the requirement?

- ☐ A An organisation trail with Object Lock in governance mode, queried with Athena
- ☐ B An organisation trail to a central bucket with versioning and MFA delete
- ☐ C Per-account trails to per-account buckets, with a nightly copy to a central bucket
- ☐ D An organisation trail to a central S3 bucket with Object Lock in compliance mode, queried with Athena

◆ PAUSE AND DECIDE

Which combination meets the requirement?

A Governance mode

The near-miss. Governance mode exists to be overridden by a privileged user, which the requirement forbids.

C Per-account trails plus copies

A member-account administrator can disable their own trail before the copy runs. The gap is in the source.

B Versioning and MFA delete

Versioning keeps old copies that a sufficiently privileged principal can still remove. It is not immutability.

D Org trail, compliance mode, Athena

An organisation trail covers all 200 accounts including new ones. Compliance mode cannot be overridden by anyone, including the root user.

THE SIGNAL

"Including the Log Archive account" is the discriminator between governance and compliance mode. Modules 10 and 19.

A platform team publishes an internal API. Consumers are in 40 accounts across two Regions. The API must be reachable privately, must not traverse the internet, and consumers must not need routes to the provider's VPC or non-overlapping CIDRs.

The provider wants to control which accounts can connect.

What should the solutions architect recommend?

- ☐ A AWS PrivateLink: an endpoint service behind an NLB, with allowed principals
- ☐ B VPC peering from each consumer VPC to the provider VPC
- ☐ C Transit Gateway attachments for all 41 VPCs
- ☐ D An internet-facing ALB restricted by security group

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 PrivateLink endpoint service
One-way access to a single service, no routing between VPCs, overlapping CIDRs are fine, and allowed principals control who may connect.
- B

 VPC peering
Requires non-overlapping CIDRs and routes on both sides, which the requirement explicitly excludes. Also 40 peerings to manage.
- C

 Transit Gateway
Provides network-level routing between all attached VPCs, which is far more access than publishing one API requires.
- D

 Internet-facing ALB
Traverses the internet, which the requirement forbids.

THE SIGNAL

"No routes and overlapping CIDRs are acceptable" is the PrivateLink signature. It connects services, not networks. Module 09.

Finance cannot determine which of 30 business units is responsible for a \$180,000 monthly increase. Resources carry a BusinessUnit tag applied by every team since the organisation began. Cost Explorer does not offer the tag as a grouping dimension.

The increase spans EC2 and data transfer.

What is the MOST likely cause, and what should be done?

- ☐ A Cost Explorer cannot group by tags; use the Cost and Usage Report instead
- ☐ B The tag has not been activated as a cost allocation tag; activate it, noting that activation is not retroactive
- ☐ C Tag policies must be enabled before tags appear in billing
- ☐ D The tag must be applied in the management account to be visible

◆ PAUSE AND DECIDE

What is the MOST likely cause, and what should be done?

- A

 Cost Explorer cannot group by tags
It can, once the tag is activated. The CUR offers more granularity but the same activation prerequisite applies.
- B

 Not activated; activate it
A tag exists on resources but is invisible to billing until activated in the management account, and activation applies only from that point forward.
- C

 Tag policies required
Tag policies standardise tag keys and values. They are unrelated to billing visibility.
- D

 Must be applied in the management account
Tags are applied to resources wherever they live. Activation happens centrally; application does not.

THE SIGNAL

The painful half is that activation is not retroactive, so this month can be attributed going forward but not backwards. Module 11.

A company is deploying Control Tower into an existing organisation with 120 accounts. Several accounts already have their own CloudTrail trails, Config recorders and custom SCPs. Leadership wants a standard landing zone without disrupting running workloads. Some accounts are in Regions Control Tower will not govern initially.

What is the correct expectation to set?

- ☐ A Existing accounts can be enrolled into Control Tower, but enrolment requires meeting prerequisites and will apply the landing zone's controls
- ☐ B Control Tower can only be deployed into a new organisation; the accounts must be migrated
- ☐ C Control Tower will automatically remove conflicting SCPs and trails without action
- ☐ D Control Tower governs all Regions automatically, so ungoverned Regions are not a concern

◆ PAUSE AND DECIDE

What is the correct expectation to set?

- A

Enrolment with prerequisites
Existing accounts enrol, and enrolment has prerequisites and applies the landing zone's controls. Setting that expectation is the architect's job.
- B

New organisations only
Control Tower can be set up on an existing organisation and can enrol existing accounts.
- C

Conflicts removed automatically
Conflicting configuration is something you must reconcile. Assuming otherwise is how enrolment fails midway.
- D

All Regions governed
Regions are governed selectively. Ungoverned Regions are a real gap and a common audit finding.

THE SIGNAL

Ungoverned Regions are the detail most people miss. Resources there are outside the landing zone's controls entirely. Module 03.

A central networking account owns subnets that application teams in 25 accounts must deploy into. The networking team must retain sole control of route tables, NAT gateways and network ACLs. Application teams must see and manage only their own instances. Each team must be billed for its own resources.

What should the solutions architect recommend?

- ☐ A Cross-account IAM roles granting teams full VPC access in the networking account
- ☐ B A VPC per team, peered to the networking account's VPC
- ☐ C VPC sharing through AWS RAM: the owner keeps the VPC and network configuration; participants deploy resources into shared subnets
- ☐ D Transit Gateway with a shared services VPC per team

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

A Cross-account roles

Teams work inside the networking account, so resources are billed there and teams can see each other's work.

B VPC per team

25 VPCs, 25 sets of route tables and NAT gateways. The networking team loses the central control the requirement demands.

C VPC sharing via RAM

Participants deploy into shared subnets and see only their own resources; the owner alone manages route tables, NAT and ACLs. Costs land in each participant's account.

D TGW plus per-team VPCs

Same objection as B, with a Transit Gateway added. It multiplies rather than centralises network configuration.

THE SIGNAL

"Owner keeps the plumbing, participants deploy into it" is the VPC-sharing signature, and billing lands in the participant account. Module 05.

A regulator requires that customer data is never processed or stored outside two European Regions, and asks for continuous evidence. Engineers currently have access to all Regions. A previous proposal to deploy a Config rule that deletes non-compliant resources was rejected.

The company uses AWS Organizations.

What should the solutions architect implement?

- ☐ A An SCP denying actions where `aws:RequestedRegion` is outside the two Regions, plus a Config rule for evidence
- ☐ B IAM policies on each role restricting Regions, plus Security Hub
- ☐ C Disable all other Regions in every account
- ☐ D A tag policy requiring a Region tag on all resources

◆ PAUSE AND DECIDE

What should the solutions architect implement?

- A

 SCP plus Config rule
The SCP refuses the API call so nothing is created elsewhere; the Config rule supplies the continuous record. "Never" plus "evidence" is always this pair.
- B

 IAM policies per role
Applies only to roles you remember to update, and any new role starts unrestricted. The ceiling is in the wrong place.
- C

 Disable other Regions
A genuine control, applied per account rather than organisation-wide, and it produces no compliance evidence.
- D

 Tag policy
Standardises tag keys and values. It does not prevent a resource being created in another Region.

THE SIGNAL

The rejected proposal is a hint, not decoration: detect-and-delete was refused, so the answer must be preventive. Modules 02 and 25.

An organisation reports Savings Plans utilisation of 99% and coverage of 38%. Compute usage has been flat for eighteen months and is forecast to remain so. Finance concludes the strategy is optimal and proposes no change.

The uncovered usage runs continuously in production.

What should the solutions architect advise?

- ☐ A Agree; 99% utilisation indicates the commitment is correctly sized
- ☐ B Increase the commitment: 62% of eligible usage is paying On-Demand rates unnecessarily
- ☐ C Reduce the commitment to improve flexibility
- ☐ D Move the uncovered usage to Spot Instances

◆ PAUSE AND DECIDE

What should the solutions architect advise?

A Agree, 99% is optimal
Utilisation of 99% says the commitment you bought is fully used. It says nothing about the 62% running at full price beside it.

C Reduce it
Backwards. High utilisation with low coverage means the commitment is too small.

B Increase the commitment
Flat, continuous, forecast to continue: exactly the profile a commitment exists for, and 62% of it is undiscounted.

D Spot
Continuous production workload is the least suitable candidate for interruption.

THE SIGNAL

Two metrics, opposite directions. Reading utilisation alone is how a good number produces a wrong conclusion. Modules 11 and 32.

Developers in a sandbox OU must be able to create IAM roles for their applications, but must never be able to create a role that grants administrative access, and must not be able to remove the restriction from roles they create.

An SCP already denies iam:CreateUser across the OU.

What should the solutions architect implement?

- ☐ A An SCP denying iam:CreateRole in the sandbox OU
- ☐ B A permissions boundary that developers must attach, enforced by an IAM condition requiring the boundary on role creation
- ☐ C A session policy applied when developers assume their role
- ☐ D An RCP on the IAM service in the sandbox OU

◆ PAUSE AND DECIDE

What should the solutions architect implement?

- A

 Deny CreateRole
Removes the ability the requirement says developers must have.
- B

 Enforced permissions boundary
The classic delegation pattern: developers create roles, the boundary caps what those roles can do, and the condition stops them creating unbounded roles.
- C

 Session policy
Limits the developer's own session. It does not constrain roles they create for applications.
- D

 RCP on IAM
RCPs govern access to resources from outside. This is about capping what a created principal may do.

THE SIGNAL

"Must be able to create roles, but the roles must be capped" is the permissions boundary signature. Module 02.

A security team wants GuardDuty, Security Hub and Config enabled in all 200 accounts and in every account created in future, with findings visible in one place. They must not have to log into member accounts to enable anything, and the management account must not be used for daily operations.

The company uses AWS Organizations.

What should the solutions architect recommend?

- ☐ A Enable each service manually and document the runbook for new accounts
- ☐ B Enable each service from the management account and operate from there
- ☐ C Use CloudFormation StackSets to enable each service per account
- ☐ D Register a security account as delegated administrator for each service, and enable auto-enable for new accounts

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A

 Manual plus a runbook
200 accounts by hand, and a runbook depends on someone following it for every new account.
- B

 Operate from the management account
The requirement explicitly excludes daily operations there, and it is the account with the widest blast radius.
- C

 StackSets
Would deploy configuration, and these services have native organisation integration that handles aggregation and auto-enable properly.
- D

 Delegated administrator plus auto-enable
Central enablement without touching member accounts, findings aggregate to the security account, and new accounts are covered automatically.

THE SIGNAL

"Not the management account for daily operations" is the delegated administrator signature, and it appears constantly. Module 10.

Two teams need access to the same DynamoDB table in a shared data account. Team A is in one account and needs read access; Team B is in another and needs read and write. The table is encrypted with a customer managed KMS key.

Team A can assume the role but every request fails with an access denied error.

What is the MOST likely cause?

- ☐ A Team A's account needs to be added to the organisation
- ☐ B The DynamoDB table needs a resource-based policy
- ☐ C The KMS key policy does not grant Team A's role permission to use the key
- ☐ D The role's trust policy is missing Team A's account

◆ PAUSE AND DECIDE

What is the MOST likely cause?

- A

 Add to the organisation
Cross-account access does not require shared organisation membership.
- B

 Resource-based policy needed
The role already exists in the data account and can be assumed. Access is being denied after assumption.
- C

 KMS key policy
Encrypted data needs both data-access and key-use permission. The key policy is the third grant people forget in cross-account access.
- D

 Trust policy
The scenario states assumption succeeds. A trust policy failure would prevent assuming the role at all.

THE SIGNAL

"Can assume the role but requests fail" localises the fault after assumption, and with a CMK the key policy is the usual culprit. Module 05.

Where to revisit

IF YOU MISSED	REWATCH
Q1, Q11, Q13	Module 02 – Guardrails: SCPs, RCPs, boundaries
Q9	Module 03 – Control Tower and landing zones
Q2	Module 04 – Identity at scale
Q10, Q15	Module 05 – Cross-account access and sharing
Q3, Q4, Q5, Q7	Modules 06-09 – Connectivity, DNS, private access
Q6, Q8, Q12, Q14	Modules 10-11 – Org-wide logging and cost

ON THE EXAM

12 or more out of 15 is on track for this domain. Below 9, rewatch before attempting the next set.